

Prototype Specification

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

33. Design Principles

Adopted from Saltzer & Schroeder [14], Yee [13], Nielsen [15], Cavoukian [27] and the usable-security literature [10, 11, 17]. Each principle names where it is applied.

#	Principle	Source	Applied in
DP-1	Authenticate the key, not the artefact. Accept only proof of possession of a secret the credential never reveals.	[2, 14] complete mediation; [4–9]	SEC-01, SEC-04, D1
DP-2	Authentication and authorization are separate decisions with separate messages.	[1, 14]	FR-04, FR-05, USE-03, screens 6 vs 7–9
DP-3	Fail secure, degrade gracefully. Every failure ends in DENY or a defined, audited manual mode; never in an open gate.	[14] fail-safe defaults	SEC-09, SEC-19, FR-14, Section 32
DP-4	Path of least resistance is the secure path. The authenticated tap must be faster than today's glance. Convenience comes from redundant credentials, not bypasses.	[13] Yee; [11] Herley; [17] compliance budget	USE-01, D1 (phone credential), rejected fallbacks in Sec 32
DP-5	Least privilege and separation of duties for every human and service role.	[14]	SEC-07, Section 21.1
DP-6	Minimise: collect, show and keep only what the decision needs.	[22, 26, 27]	SEC-08, SEC-14, PRIV-01..05, PRIV-10
DP-7	Make security state visible to the operator. Online/offline, list age, alerts, decision and reason are always on screen.	[13] visibility; [15] #1	USE-06, screen 16 status bar
DP-8	Plain language, one glance, one next step. Guard messages are bilingual, non-technical, and always end with an action.	[12, 16]; [15] #9	USE-02, USE-04, USE-05
DP-9	Reversibility where safe, irreversibility where necessary. Admin actions confirm before applying; revocation is irreversible by design.	[13] revocability; [15] #3, #5	USE-10, SEC-17
DP-10	Open design. Only keys are secret; standard primitives and libraries only.	[14] open design	SEC-20
DP-11	Accountability without surveillance. Everything is logged; logs are pseudonymous; re-identification is justified and itself logged.	[22, 26]	SEC-10, PRIV-04, PRIV-06
DP-12	Accessible by default. Multimodal feedback; reachable hardware; no colour-only signals.	[28]	USE-08, USE-09, USE-14
DP-13	Dignity on denial. A denied person is told what to do next, privately, without being interrogated in front of a queue.	Meher persona; [10]	PRIV-10, USE-13, user-facing screens 6–9

34. Design Decisions

Decision matrix. "User evidence" cites primary data where it exists; until fieldwork is complete those cells read [DATA REQUIRED] and the decision rests on the other columns plus labelled assumptions.

ID	Decision	Options considered	User evidence	Security implication	Privacy implication	Usability implication	Feasibility	Final direction (provisional)
D1	Primary credential technology	(a) Static QR; (b) LF RFID; (c) AES smart card; (d) NFC phone only; (e) Dynamic QR only; (f) Hybrid card + optional phone (NFC/dynamic QR)	Q16 preference, Q17 phone capability, Q18 accessibility, observation timing [DATA REQUIRED]	(a),(b) fail SEC-01 (copyable). (c) strongest single option; single-factor. (d) two-factor via unlock but excludes non-phone users. (e) replay within window; slow. (f) baseline strength of (c), convenience of (d)/(e)	(b) fixed UID trackable; (c) random-UID chips available; (d)/(e) pseudonymous tokens	(c) fastest, most accessible, but card retrieval (H1); (d) phone in hand; (e) slowest	(c) moderate cost; (d) iOS restriction; (e) trivial; (f) most Phase 2 work	(f) Hybrid: AES smart card for everyone; optional phone credential (Android NFC or dynamic QR); visitor signed QR. Revisit after Q16/Q17.
D2	Manual fallback when infrastructure fails	(a) Guard visual check + admit ("allow anyway"); (b) Gate closed until restored; (c) Offline verified mode with bounded staleness, then supervised manual mode with logging	B Q10, observation of current fallbacks [DATA REQUIRED]	(a) recreates today's weakness and invites DoS→bypass (TH-14). (b) DoS = campus closed. (c) bounded risk, full accountability	(c) manual records hold guard/supervisor IDs; acceptable	(a) fastest; (b) unacceptable; (c) slower only in rare prolonged outage	(c) needs local storage and sync; moderate	(c) Offline-verified ≤ N h → supervised Manual Verification Mode; no "allow anyway" control exists.
D3	Information shown to guard	(a) Full record (name, roll, dept, hostel, phone); (b) Photo + full name + roll no.; (c) Photo + first name + role + decision + next step; (d) Decision only, no photo	B Q11/Q12, Q14c [DATA REQUIRED]	(d) removes the human check against borrowing/relay (TH-04). (a)/(b) make guard a data-exposure vector (TH-13)	(a) worst; (c) minimal set that still supports the decision; (d) best privacy but weakens security	(c) one glance; (a) clutter slows decision	All feasible	(c). Photo from server, not card. Roll no. never shown (guard has no use for it).
D4	Visitor authentication	(a) Paper register; (b) Guard enters visitor details on tablet; (c) Host pre-approval → signed time/gate-bound QR pass; (d) Visitor self-registration kiosk without host	B Q9, observation H6 [DATA REQUIRED]	(a)/(b) no authentication of the visitor's claim; (d) anyone can self-approve; (c) authenticates the approval, binds it to window and gate	(a) exposes previous visitors' data; (b) guard holds contact data; (c) guard sees name + host only, contact used for delivery only	(c) ≤10 s at gate if pre-approved; unapproved path needs host response	(c) needs host app/portal and notification; moderate	(c), with gate-initiated host approval for walk-ins. No paper register.
D5	Logging	(a) No logs (privacy-maximal); (b) Full identified logs; (c) Pseudonymous logs, separate mapping, justified re-identification, fixed retention	Q14a, Q14b, Q15b [DATA REQUIRED]	(a) no incident response, no anomaly detection (TH-15). (b) surveillance dataset; breach impact high (TH-10, TH-13). (c) both goals	(c) minimises movement-data exposure; DPDP alignment [22]	(c) auditor workflow slightly slower (justification step)	(c) moderate	(c) with 90-day retention, hash-chained integrity, student self-view.
D6	Credential revocation	(a) Issuer-only, office hours; (b) Self-service immediate + issuer; (c) Self-service with 24 h "undo"	Q9, Q10 [DATA REQUIRED]	(a) leaves lost card live for hours/days (TH-01). (c) undo creates ambiguity and a social-engineering path. (b) closes window fastest and is unambiguous	(b) student controls own credential	(b) seconds from phone; replacement still needed	(b) easy	(b) Self-service immediate, irreversible; replacement issued instead of un-revoke.
D7	Failure handling behaviour	(a) Fail-open on any error (availability first); (b) Fail-closed with no fallback; (c) Ordered degradation: online → offline-verified → manual supervised → emergency egress-only	B Q10 [DATA REQUIRED]	(a) any fault = free entry (TH-14, TH-16). (b) availability failure. (c) each stage keeps a defined level of authentication and full logging	(c) manual records contain more human attribution; acceptable	(c) only prolonged outage is slow	(c) moderate	(c) with N = 4 h default (configurable), emergency egress never blocked.
D8	Authentication vs authorization messaging	(a) Single "Denied"; (b) Technical codes; (c) Two classes with plain-language reason and role-specific detail	B Q13 training, Q19 expectations [DATA REQUIRED]	(c) lets guard respond correctly (revoked ≠ fake ≠ expired); prevents guards "helping" a NOT RECOGNISED case	(c) reason for revocation withheld from guard	(c) requires ≤15 min training (USE-02)	Easy	(c)
D9	Handling forgotten card without phone credential	(a) Guard admits on verbal identity; (b) Refuse until card produced; (c) Security Office issues one-day signed temporary pass after roster + photo verification	Q7, Q19 [DATA REQUIRED]	(a) social-engineering path (TH-04). (b) strands legitimate students; pressure to bypass. (c) authentication moves to a trained issuer with server data; pass is bounded	(c) no public interrogation	(c) detour but defined and dignified	(c) reuses visitor-pass machinery	(c)

ID	Decision	Options considered	User evidence	Security implication	Privacy implication	Usability implication	Feasibility	Final direction (provisional)
D10	Phone credential platform	(a) Android HCE + iOS QR; (b) QR-only on both; (c) Native wallet passes (Apple/Google)	Q17 [DATA REQUIRED]	(a) NFC where possible, QR elsewhere; (c) strongest but requires platform partnership	Similar	(a) mixed experience; (c) best	(c) infeasible for a course project; (a) feasible	(a) for Phase 2; (c) noted as future direction

35. Prototype

35.1 Overview

Lo-fi, greyscale wireframes suitable for import into Figma. Three surfaces: Gate user indicator (small display or LED + text facing the person, portrait phone-sized), Guard tablet (landscape 10"), Admin / student web and app (desktop or phone). Files: 06_Prototype/Prototype_Screens.pdf (all 20 screens) and 06_Prototype/screens/S01..S20.png. Figma import instructions in 06_Prototype/Figma_Prototype_Instructions.pdf.

Conventions: status colours are always paired with an icon and a word (USE-08); Hindi labels appear under English on guard/user screens (shown as "[HI]" in wireframes to keep them legible; final copy to be translated); every DENY screen has a "Next step" block; no guard screen has an "Allow" control.

35.2 Screen specifications

S01 — Welcome / Gate Authentication (user indicator, idle)

- Purpose: Tell the approaching person what to do and show the lane is working.
- UI elements: Large icon of card/phone tapping; text "Tap card or phone / [HI]"; small QR camera indicator "or show app QR"; status dot (green = ready, amber = offline mode, grey = lane closed).
- Buttons: none (no touch on user side).
- Information shown: instruction; lane status.
- Deliberately hidden: any previous person's result; system internals.
- User action: approach and tap.
- System response: transitions to S02/S03 on read.
- Security: idle screen reveals nothing; lane-closed state prevents use of a disabled reader (SEC-18).
- Privacy: no data.
- Usability: recognisable affordance; USE-14 reader height note in spec; USE-09 contrast.

S02 — Scan / Tap ID (user indicator, reading)

- Purpose: Confirm the reader has detected a credential and guide correct positioning.
- UI: Animated ring around tap zone; text "Hold still..."; for QR: camera frame with "Align code / tilt to avoid glare"; hint after 2 failures: "Try card or NFC".
- Buttons: none.
- Shown: method detected (card / phone / QR icon).
- Hidden: credential ID.
- User action: hold.
- System response: → S03.
- Security: nonce challenge starts here; nothing accepted without completion (SEC-01).
- Privacy: none.
- Usability: error prevention hints (USE-04); retry without reset (USE-12).

S03 — Authentication in progress (user indicator + guard tablet strip)

- Purpose: Cover the ≤1 s verification with clear status so people don't re-tap.
- UI: Spinner + "Verifying..."; guard tablet shows thin progress strip.
- Buttons: none.
- Shown: progress only.
- Hidden: which step (authn vs authz) is running; identity.
- System response: → S04/S05 or S06–S09.
- Security: timeout → DENY–NOT RECOGNISED, never ALLOW (SEC-09).
- Privacy: none.
- Usability: Nielsen #1; if > 2 s show "Taking longer than usual" (USE-06).

S04 — Authentication success (user indicator)

- Purpose: Tell the person they may proceed.
- UI: Full green background, large ✓, "Welcome — go ahead / [HI]"; short tone; auto-clear on pass or 5 s.
- Shown: result only. Hidden: name (bystanders), any identity data (PRIV-10).
- User action: walk through.
- System response: logs event; guard tablet shows S05 simultaneously.
- Security: ALLOW shown to user only after both authn and authz pass (FR-05).
- Privacy: no name on user side.
- Usability: colour + icon + tone (USE-08).

S05 — Authorization success (guard tablet)

- Purpose: Let the guard confirm the face in one glance.
- UI: Left 40%: photo on file (large). Right: "ALLOWED ✓" (green band, 24 pt), first name, role chip ("Student"), gate + time small; bottom-right large secondary button [Mismatch X]; status bar (online, list age, alerts).
- Buttons: [Mismatch] only. No [Allow].
- Shown: photo, first name, role, decision. Hidden: full name, roll no., programme, hostel, phone, method used, credential ID (SEC-08).
- Guard action: glance; press Mismatch if face differs.
- System response: Mismatch → DENY–SUSPICIOUS, flag with guard ID, user indicator turns red (S09).
- Security: server photo defeats printed-photo forgery; Mismatch is the anti-relay/anti-borrowing control (FR-12, TH-04).
- Privacy: minimal set (PRIV-03); photo URL expires in 60 s; screen auto-clears.
- Usability: photo-first layout; one word status; USE-05; Mismatch is large but requires confirm-tap to avoid accidental denial (USE-10).

S06 — Access denied: not recognised (guard tablet + user indicator)

- Purpose: Authentication failed; nothing is known about this person.
- Guard UI: Red band "NOT RECOGNISED X"; body: "This is not a valid campus credential." Next step: "Do not admit. Direct the person to the Security Office. If they insist: [Call supervisor]". Buttons: [Call supervisor], [Done].
- User UI: Red X, "Not accepted — please visit the Security Office / [HI]". No reason.
- Shown: decision class, next step. Hidden: any identity (none exists), technical error code (available to auditor only).
- Security: fake/cloned/replayed credentials all land here (SEC-01, SEC-04); guard is never asked to judge authenticity; SEC-13 counter increments.
- Privacy: user message gives no bystander information.
- Usability: USE-03 (distinct from authz failures), USE-04 (next step), USE-11 (script on screen).
- Variant S06b — Not authorized here/now: amber band "NOT PERMITTED AT THIS GATE/TIME"; photo + first name shown (identity known); next step: "Direct to [permitted gate] or Security Office."

S07 — Credential expired (guard tablet + user indicator)

- Purpose: Identity known; validity lapsed.
- Guard UI: Amber band "EXPIRED"; photo + first name + role; "Credential validity ended." Next step: "Do not admit. Direct to ID cell for renewal. If the person says they are a current member: [Call supervisor]". Buttons: [Call supervisor], [Done].
- User UI: Amber !, "Credential expired — please renew at the ID cell / [HI]".
- Hidden: exact expiry date on user side (bystanders); roll no.
- Security: SEC-03; authn passed so photo is shown to help the guard direct the right person.
- Privacy: minimal.
- Usability: different colour and next step from S06 and S08 (USE-03).

S08 — Credential revoked (guard tablet + user indicator)

- Purpose: Identity known; credential revoked or suspended.
- Guard UI: Red band "REVOKED"; photo + first name; "This credential has been revoked." Next step: "Do not admit. Direct to Security Office." Buttons: [Call supervisor], [Done]. Event auto-flagged.
- User UI: Red X, "Not accepted — please visit the Security Office / [HI]" (same wording as S06 to bystanders).
- Hidden: reason for revocation (SEC-08); whether it was lost vs disciplinary.
- Security: SEC-02; flag supports Scenario 1/7 investigation.
- Privacy: reason withheld protects the student from stigma.
- Usability: guard needs no judgement; DP-13 dignity.

S09 — Suspicious credential (guard tablet + user indicator)

- Purpose: SEC-13 escalation or guard Mismatch.
- Guard UI: Red band "SUSPICIOUS — SUPERVISOR ALERTED"; if identity known: photo + first name; text: "Repeated failed attempts / face mismatch recorded." Next step: "Do not admit. Keep the person at the gate if safe. Supervisor has been notified." Buttons: [Call supervisor] (pre-dialled), [Done].
- User UI: Red X, "Not accepted — please wait for security staff / [HI]"
- Hidden: which rule triggered; thresholds.
- Security: TH-02, TH-04, TH-06 detection path; reader rate-limited.
- Privacy: minimal.
- Usability: guard is told an alert has already gone out (reduces burden); safety wording.

S10 — Reader failure (guard tablet)

- Purpose: Hardware fault or tamper.
- UI: Grey/amber band "READER OFFLINE — Lane 1"; cause class (self-test failed / tamper detected / no power); Next step: "Direct people to Lane 2" or, if no other lane, "Start Manual Verification Mode" [button, supervisor PIN required]. Status bar shows reader health.
- Hidden: technical diagnostics (auditor).
- Security: reader disabled server-side; tamper logged (SEC-18); manual mode requires supervisor (FR-19).
- Privacy: none.
- Usability: USE-06 visibility; clear alternative.

S11 — Network failure (guard tablet)

- Purpose: Show offline-verified mode and its bounded validity.
- UI: Status bar amber "OFFLINE — verifying locally. Revocation list age: 1 h 20 m (limit 4 h)". Main area unchanged (S05-style results continue). If age > limit: modal "Offline limit reached — Manual Verification Mode required" [Start manual mode — supervisor PIN].
- Hidden: server details.
- Security: SEC-19; countdown makes staleness visible; automatic transition to manual when limit exceeded.
- Privacy: none.
- Usability: guards keep working normally; only the bar changes.

S12 — Manual verification / fallback (guard tablet)

- Purpose: Defined procedure when electronic verification is impossible.
- UI: Header "MANUAL VERIFICATION MODE — all entries are recorded and reviewed"; step list: 1. Ask for card or app screen. 2. Compare face with card photo. 3. Select credential type shown [Card] [Phone] [None]. 4. Photo check result [Matches] [Does not match]. 5. [Request supervisor approval] → supervisor enters PIN on tablet (or approves batch for peak). 6. Result: "Admit" or "Do not admit". Emergency variant: [Emergency ingress] (supervisor-only) with reason field.
- Buttons: as listed; no free-text personal data entry.
- Shown: procedure; supervisor approval state. Hidden: any lookup of student records (deliberately unavailable: DP-6).

- Security: weakest mode, so every decision carries guard + supervisor IDs and is flagged (FR-19, TH-17); no roster lookup prevents data exposure and interrogation; egress always free (FR-20).
- Privacy: no personal data typed; record holds only credential type and outcome.
- Usability: USE-11 recognition; paper fallback mirrors these steps.

S13 — Visitor registration (host web/app; guard tablet variant for walk-ins)

- Purpose: Host requests a pass.
- UI: Form: visitor name; purpose category (dropdown: academic / official / personal / vendor); date; time window; gate(s) (checkboxes); delivery channel (e-mail or phone, used only to send the pass — inline notice). [Submit request].
- Guard variant ("Visitor without approval"): host search by name/department → [Send approval request to host]; waiting state; no visitor data entered by guard except name.
- Hidden: visitor contact on guard variant (PRIV-09).
- Security: request authenticated as the host (SSO); FR-10.
- Privacy: purpose is a category, not free text; contact used for delivery only; retention notice shown.
- Usability: ≤1 min for host; walk-in path needs no typing beyond host name.

S14 — Visitor approval (approver or host phone)

- Purpose: Approve/decline a pass request.
- UI: Card: visitor name, purpose category, window, gates, requester. [Approve] [Decline] [Edit window]. Auto-approval note if policy allows hosts to self-approve for some categories.
- Hidden: visitor contact (not needed to decide).
- Security: MFA session for approver role; decision logged (SEC-12).
- Privacy: minimal.
- Usability: one-tap on phone; walk-in requests appear as push notification.

S15 — Temporary visitor credential (visitor phone / printed slip)

- Purpose: The pass itself.
- UI: QR code (large); "VISITOR PASS"; visitor first name; host name; "Valid: 1 Oct 2026, 14:00–17:00"; "Gate: Main"; "Single entry"; footer: "Show this at the gate. Do not forward. Data deleted 30 days after visit."
- Hidden: pass ID in human-readable form; host contact.
- Security: server-signed token; window, gate set, use-count embedded (SEC-16); QR contains no personal data beyond first name (which is displayed anyway).
- Privacy: retention notice (PRIV-07).
- Usability: works printed or on screen; large QR for outdoor scanning.

S16 — Security guard dashboard (guard tablet, home)

- Purpose: Between taps: lane status, alerts, quick actions.
- UI: Status bar (online/offline, list age, reader health, time); tiles: "Waiting for tap"; alerts list (supervisor-acknowledged state); quick actions [Visitor without approval] [Call supervisor] [Report reader problem]; today's gate count (aggregate number only).
- Hidden: any list of who has entered (guards do not need it; PRIV-03); names in alerts (pseudonym + photo only when the person is at the gate).
- Security: role-limited (SEC-07); no search function.
- Privacy: aggregate counts only.
- Usability: USE-06; large touch targets for outdoor use.

S17 — Admin credential management (issuer console)

- Purpose: Issue, renew, suspend, revoke.
- UI: MFA badge in header; roster search (name/roll); identity card showing only SEC-14 fields (name, roll, programme, photo, role); credential list per identity with status chips (ACTIVE / SUSPENDED / EXPIRED / REVOKED) and validity dates; actions per credential: [Renew] [Suspend] [Revoke]; identity-level: [Issue new card] [Send phone enrolment]. Every action opens a confirm dialog stating exact effect and requiring a reason

(dropdown).

- Hidden: keys (never displayed; only "key present in HSM"); entry logs (different role); other admins' actions (auditor).
- Security: SEC-07, SEC-11, SEC-12; roster match required to issue (FR-07).
- Privacy: no phone/address fields exist to display (PRIV-01).
- Usability: recognition over recall (roster search, not typed IDs) (USE-11); USE-10 confirms.

S18 — Lost ID / revoke credential (student app; issuer variant)

- Purpose: Self-service immediate revocation.
- Student UI: "My credentials": Card ····1234 [ACTIVE], Phone (this device) [ACTIVE]. Tap card → [Report lost or stolen]. Confirm sheet: "This will permanently disable your card. Your phone credential keeps working. A replacement request will be created. This cannot be undone." [Report and disable] [Cancel]. Result: card [REVOKED], "Replacement requested — status: pending. Collect at ID cell with a photo ID."
- Issuer variant: same action from S17 with reason selector.
- Hidden: nothing sensitive; student sees own data only.
- Security: SEC-17 irreversible; requires app login; logged (SEC-12).
- Privacy: student controls own credential.
- Usability: two taps; consequences stated before action (USE-10); Meher persona T4.

S19 — Entry logs (auditor console)

- Purpose: Review decisions and investigate incidents without casual identification.
- UI: Filters: gate, date/time range, decision code, flagged only, method. Table columns: time, gate, method, decision, credential pseudonym (e.g., "C-7f3a..."), flags, guard ID (manual entries only). Integrity indicator: "Chain verified ✓ (last checkpoint 12:00)". Row action: [Re-identify] → dialog: case reference (required), justification (required), notice "This action is logged and visible to [second admin role]" [Confirm]. After confirm: name and roll appear for that row only, with a red "identified" badge.
- Hidden: names by default (PRIV-04); secrets (SEC-06); no edit/delete controls anywhere (SEC-15).
- Security: SEC-10 chain status; PRIV-06 justified re-identification; Auditor role only.
- Privacy: pseudonymous by default; re-identification is the exception and is itself audited.
- Usability: flagged-only quick filter for daily review; export is pseudonymous.

S20 — Privacy / access-control screen (two variants)

- Student variant (app "Privacy & my data"): sections: "What is collected" (list per Section 30); "Why" (access decisions, security incidents); "Who can see it" (visibility table simplified); "How long" (90 days; flagged until case closed); "My entry records" (own events list, last 90 days); "My credentials"; "Request correction"; link to full notice.
- Policy admin variant ("Gate access policy"): table of gates × roles × time windows; edit opens confirm dialog showing before/after and "applies to N gates"; version history with author and time; default row "Any other role: DENY" (non-editable) to make the secure default visible.
- Hidden: student variant shows no other person's data; policy variant shows no individual identities.
- Security: policy changes MFA + confirm (SEC-11), versioned (FR-18); deny-by-default visible (DP-3).
- Privacy: PRIV-07 transparency, PRIV-08 access; builds trust (USE-13).
- Usability: plain-language notice; policy grid uses recognition (USE-11).

35.3 Screen flow map

S01 → S02 → S03 → { S04 (user) + S05 (guard) } → auto-clear → S01
 → S06 / S06b / S07 / S08 / S09 (user: red/amber message; guard: next step) → [Done] → S16
 S05 → [Mismatch] → S09
 S16 → [Visitor without approval] → S13 (guard variant) → S14 (host phone) → S15 → S02
 S16 → reader fault → S10 ; network loss → S11 ; limit exceeded → S12
 Host web → S13 → S14 → S15
 Student app → S18 ; → S20 (student)
 Issuer console → S17 → (confirm) ; → S18 (issuer variant)
 Auditor console → S19
 Policy admin → S20 (policy)

35.4 Figma import notes

Import screens/S01..S20.png as frames at 1440×900 (tablet/desktop) or 390×844 (phone/user indicator); link hotspots as in 35.3; use Figma's prototype "Overlay" for confirm dialogs (S17, S18, S19, S20). Full instructions in [Figma_Prototype_Instructions.pdf](#).

36. Heuristic Evaluation

This is an initial heuristic evaluation by the design team, not user testing. No students, guards or administrators have used the prototype. Findings are expert judgements against Nielsen's heuristics [15] and usable-security principles [13, 14, 27]. Each finding has a severity (0 none, 1 cosmetic, 2 minor, 3 major, 4 catastrophic) and a planned fix. User testing with real participants is a Phase 2 activity (Section 40).

Method. Two evaluators walked through tasks T1–T10 (Section 18) on the 20 wireframes independently, recorded violations, then merged and rated them.

36.1 Nielsen's heuristics

Heuristic	Assessment	Findings (severity)	Planned fix
1. Visibility of system status	Strong: status bar on every guard screen (online/offline, list age, reader health); user indicator shows ready/reading/verifying/result.	HE-1 (2): S03 gives no indication of how long is normal; a slow network could make users re-tap.	Add "usually under 2 s" and a 2-s "taking longer" message (already in spec; ensure in wireframe).
2. Match between system and real world	Good: "Not accepted", "Expired", "Revoked", "Security Office", "ID cell" are terms guards and students use. Bilingual labels planned.	HE-2 (2): "Revocation list age" (S11) is technical vocabulary for guards.	Rename to "Last update from server: 1 h 20 m ago (limit 4 h)".
3. User control and freedom	Admin actions have Cancel; Mismatch requires confirm; guard can [Done] out of any result. Deliberate limitation: no "Allow anyway" (security override of this heuristic, justified in Section 38).	HE-3 (1): S09 has no explicit way for the guard to dismiss a false alert other than [Done]; supervisor owns resolution.	Acceptable; add "Supervisor will clear this alert" text.
4. Consistency and standards	Colour/word/icon triad consistent across S04–S09; red = deny, amber = authz-class deny with known identity, green = allow.	HE-4 (3): S06b "Not permitted at this gate/time" is amber, as are Expired (S07) — two different next steps share a colour.	Keep amber for both (both are "identity known, not authorized") but make the status word and next-step block the primary differentiator; add distinct icons (clock vs gate).
5. Error prevention	Confirm dialogs on revoke/policy; Mismatch confirm; QR glare hints; no free-text personal data in manual mode.	HE-5 (2): S13 host form allows any time window; a host could create a week-long pass.	Policy-driven maximum window (e.g., 12 h) enforced in form with explanation.
6. Recognition rather than recall	Next-step scripts on screen; roster search in S17; policy grid in S20.	HE-6 (2): S12 manual mode step list is long for a stressed guard in a queue.	Collapse to 3 large steps with progressive disclosure; provide printed card at gate.
7. Flexibility and efficiency	Back-to-back taps; auto-clear; flagged-only filter in S19; two credential methods.	HE-7 (1): Supervisors may want batch approval in manual mode at peak; spec mentions it, wireframe does not show it.	Add [Approve next 10 min] control for supervisor role only, logged as such.
8. Aesthetic and minimalist design	Guard result screens contain photo, one name, one status word, one line, one button.	HE-8 (1): S16 dashboard tiles risk clutter if alert list grows.	Cap visible alerts at 3 with count badge.
9. Help users recognise, diagnose, recover from errors	Every DENY names the class and next step; user side gives a respectful, non-specific message.	HE-9 (3): S06 user message "Not accepted — visit the Security Office" is identical for fake credential and revoked credential (by design, for bystander privacy), which means a legitimate student with a revoked card gets no private explanation at the gate.	Send a private explanation to the student's app immediately ("Your card was revoked on ... because a loss was reported. Visit ..."). Keeps bystander message generic.
10. Help and documentation	Scripts embedded; training target ≤15 min (USE-02).	HE-10 (2): No on-screen "What do these colours mean?" help for a relief guard.	Add a persistent "?" on S16 opening a one-page legend.

36.2 Usable-security principles

Principle	Assessment	Findings	Planned fix
Visible security state [13]	Online/offline, list age, tamper, alerts all visible; decision shows both authn and authz outcome.	HE-11 (2): The guard cannot tell from S05 which method (card/phone/QR) was used; this could matter if policy later restricts methods for certain gates.	Add small method icon to S05 (not to user side).
Safe defaults [14, 27]	Deny-by-default policy is shown in S20; new readers disabled; minimal guard view; retention on.	None.	—
Security effort proportional to risk [17]	Routine entry = one tap; additional steps only on anomalies, manual mode, admin ops.	HE-12 (2): Mismatch confirm-tap adds a step in the moment the guard most needs speed (a person trying to walk through).	Make first tap immediately turn the user indicator red (stop the person) and log a provisional flag; second tap confirms; single tap auto-confirms after 3 s.

Principle	Assessment	Findings	Planned fix
Reversibility [13]	Admin actions confirm; suspension reversible; revocation deliberately irreversible with replacement path.	HE-13 (2): Student self-revoke (S18) is irreversible with no cooling-off; accidental taps are possible.	Keep irreversible (security), but require typing "DISABLE" or biometric confirm; show consequence text (already present).
Data minimisation [22, 27]	Guard sees photo + first name + role; logs pseudonymous; visitor contact hidden from guard; no phone/address stored.	HE-14 (1): S15 visitor pass shows host full name; first name + department may suffice.	Show host first name + department.
Clear security explanations [12]	Reasons are plain-language; technical codes hidden from guards, available to auditors.	HE-15 (3): S06 ("not a valid campus credential") could be read by a guard as "the student is lying"; risk of confrontation.	Reword: "The reader could not verify this card or code. This can happen with damaged, copied or non-campus credentials. Direct to Security Office."

36.3 Summary

15 findings: 0 catastrophic, 3 major (HE-4, HE-9, HE-15), 9 minor, 3 cosmetic. All three major findings concern communication of denial and will be fixed in the next wireframe iteration before Phase 2 development. The evaluation confirms the prototype's structural decisions (authn/authz separation, minimal guard view, no override) but shows that wording and colour differentiation need refinement, which is exactly what user testing with guards in Phase 2 will validate.